



TECHNICAL BRIEF • 2026

Architecture, security & standards alignment.

A reference document for engineers, hosting providers, publishers, and technical reviewers — the stack, the security posture, the standards we align with, and the player-protection commitments built into a regulated betting platform.



What 50pick is, technically

50pick is a regulated, mobile-first prediction-markets platform. Modern web stack — TypeScript end-to-end, server-rendered React, PostgreSQL persistence — with a security posture and compliance alignment built specifically for the gambling industry. Everything below is the production architecture: defence-in-depth at every tier, standards-aligned at every layer, and built to satisfy a Stage-1 ISO 27001 reviewer's first walk-through.

10+

REGULATORY FRAMEWORKS
ALIGNED

2-factor

SMS-OTP FOR PLAYERS ·
TOTP FOR STAFF

**Audit-
grade**

TAMPER-EVIDENT, HASH-
CHAINED LOG OF EVERY
ACTION

Engineering principles

- **No client-trust.** Every mutation is server-validated; the client never authorises a write.
- **Defence in depth.** Edge headers, CSRF binding, role-checked actions, parameterised data access, hash-chained audit. No single layer's failure exposes the next.
- **Schema is the contract.** Strict types end-to-end. A mismatch between any two services fails at compile, not at a player's wallet.
- **Cloud-platform-agnostic.** Standard managed-PostgreSQL endpoint and a Node runtime — runs on any major hosting provider without code change.
- **Observability by construction.** Every state change is logged, every privileged action is keyed to an actor, every error path is bilingual and structured.

Production technology choices

WEB FRAMEWORK	Next.js (React) with the App Router. Server-rendered pages with streaming. Server-side action layer for every mutation — every write is bound to the origin and validated server-side before reaching business logic.
LANGUAGE	TypeScript, strict mode, end-to-end. The same types flow from the database schema through the service layer to the React components.
DATABASE	PostgreSQL via a typed ORM. All queries are parameterised — SQL injection is structurally impossible. Migrations are versioned in source control and applied automatically on deploy.
RUNTIME	Node 22 LTS. Cloud-platform-agnostic deployment — the application requires only a Node runtime, a managed PostgreSQL endpoint, and standard environment variables.
AUTHENTICATION	Phone + password with SMS-OTP two-factor at sign-in (production) and TOTP (RFC 6238) as a second factor for staff accounts. Passwords crypt-hashed with per-user salt; common-password blacklist enforced server-side.
SESSIONS	HMAC-SHA-256-signed, HttpOnly cookies with the standard secure flags. Idle and absolute expiry both enforced. Tampering is detected on every request.
AUDIT LOG	Append-only, HMAC-chained. Every entry's hash includes the previous entry's hash, producing a Merkle-style chain. Tamper detection is $O(n)$ and verifiable by any party with the chain secret.
VALIDATION	Schema-driven input validation on every server action. No trust of the client wire shape — bad payloads return clean structured errors before reaching the service layer.

DESIGN SYSTEM

Token-driven Tailwind. Every colour, font, and spacing value is a CSS variable defined once in the kit. Brand consistency by construction; accessibility (WCAG 2.1 AA) baked into the contrast tokens.

QUALITY GATE

Comprehensive automated test suite covering player flows, operator flows, and a regulator-aligned control matrix. Runs against a real browser on every change.

Highlights

Standard web-application security is necessary but not sufficient for a regulated betting product. The procedures below are the gambling-industry additions on top of the OWASP Top 10 baseline.

TWO-FACTOR AUTHENTICATION

SMS-OTP for player sign-in. TOTP (authenticator app) for every staff role. Both events audited with IP and user-agent.

ACCOUNT INTEGRITY

Strong-password policy with public-breach blacklist. Account locks after repeated wrong tries. Idle sessions kick automatically. Per-IP and per-phone rate limits stop credential stuffing.

KYC + AGE VERIFICATION

National-ID (NIDA) backed identity verification before any withdrawal. 18+ age gate enforced server-side at registration; a date-of-birth in the future or under 18 is rejected, not redirected.

AML THRESHOLDS

Transactions above the FATF threshold queue for compliance review. Each decision is logged with reason; nothing settles without a reviewer's recorded sign-off.

TWO-OFFICER SETTLEMENT

Market resolution requires two distinct officer confirmations. The same officer can never confirm twice. Stage one stages the outcome; stage two settles.

TAMPER-EVIDENT AUDIT

Every state change is hash-chained — login attempts, wallet movements, KYC submissions, market resolutions, admin decisions. A modified entry breaks the chain on next verify.

RESPONSIBLE-GAMBLING CONTROLS

Self-set deposit and loss limits. Reality-check pop-ups. One-click cooling-off. Two-step self-exclusion (24 hours through permanent). All server-enforced — bypass is not a UI question.

MATCH-INTEGRITY FEED

Live integrity-monitor feed for every football market. Anti-fraud module flags suspicious bet patterns for review before settlement.

PII DISCIPLINE

Phone numbers masked in every UI. PII never appears in error messages, health endpoints, or audit payloads. Right-to-export and right-to-erasure flows for the data-protection authority.

DEFENCE-IN-DEPTH AUTHORISATION

Privileged actions check the actor's role at the request gate *and* inside the action handler. A leaked action identifier never grants admin write privileges.

Frameworks & how we satisfy them

FRAMEWORK	DOMAIN	ALIGNMENT
LCCP · UK Gambling Commission Licence Conditions & Codes of Practice	Player protection, AML, integrity	SR Code 2.4 (responsible-gambling controls), 5.1.5 (visible 18+, helpline, RG link on every page), 2.6 (account security), 2.10 (audit-trail), 2.13 (financial integrity), 2.14 (anti-fraud).
GBT · Gaming Board of Tanzania	National licensing	Pre-application packet drafted. Pool model classified as betting pending regulator confirmation. Helpline and licence reference visible on every page footer.
ISO 27001	Information security management	A.9 access control (RBAC + role gates), A.12.3 backup (daily managed PostgreSQL backups + weekly external archive), A.12.4 logging (hash-chained audit), A.18.1 compliance.
OWASP Top 10 (2021)	Web-application security	A01 Broken access control · defence-in-depth role checks. A02 Cryptographic failures · scrypt + HMAC. A03 Injection · parameterised queries + schema-validated input. A04 Insecure design · documented threat model. A05 Security misconfiguration · strict CSP + secure headers. A07 Identification & authentication · two-factor + logout + idle expiry. A09 Security logging · hash-chained audit.
OWASP ASVS L2	Application Security Verification Standard	Targeting Level 2 today; Level 3 reachable as the platform scales.
PDPA · Tanzania Personal Data Protection Act (2022)	Personal data protection	Phone masked in every UI. PII never in health endpoints, error messages, or audit payloads. Right-to-export and right-to-erasure flows for the data-protection authority.
FATF Recommendations	Anti-money-laundering	Threshold transactions queue for compliance officer review. Each approval or escalation is logged with reason. Audit-trail retention sized to the FATF retention window.

FRAMEWORK	DOMAIN	ALIGNMENT
TCRA	Tanzania telecommunications	Licensed sender-ID for SMS delivery. Outbound communication gated by a provider abstraction; provider switch is configuration only.
WCAG 2.1 AA	Accessibility	Colour-contrast tokens. Every interactive element has an accessible label. Full keyboard navigation. Reduced-motion preference respected.
RFC 6238	TOTP for staff	Time-based one-time passwords for every staff role. Provisioned once, verified on every sensitive admin transition.

How the pieces fit, at altitude

EDGE	Strict HTTP-security headers on every response. CSP, framing protection, MIME-type discipline, referrer trim, permission lock-down, strict-transport in production.
APPLICATION TIER	Server-rendered React with streaming. Server-side action layer for every mutation — bound to the origin, validated end-to-end, logged on success and on failure.
SERVICE LAYER	Typed business-logic services for identity, KYC, wallet, market, bet, integrity, AML, and responsible gambling. All financial fields are integer; no floating-point arithmetic touches a ledger.
AUDIT CHAIN	Append-only, HMAC-linked log alongside the live database. Every state change emits one entry with the previous entry's hash baked in.
PERSISTENCE	Managed PostgreSQL. Daily backups with weekly external archive into cold storage for the regulator-mandated five-year retention window.

Data domains

The schema is drawn at the regulator's mental altitude — identity, KYC, money, betting, integrity, compliance, partners — so a data request from the Gaming Board, the FIU, or an internal compliance review walks in the same three steps.

IDENTITY Players, sessions, devices, two-factor secrets, role assignments.	MONEY Wallets, transactions, immutable ledger entries, AML review queue.	BETTING Markets, pools, positions, bundles, settlement records.
--	--	---

INTEGRITY

Anti-fraud flags, match-integrity checks, source-of-truth registry.

COMPLIANCE

KYC submissions, responsible-gambling settings, notifications, audit log.

PARTNERS

Affiliate agents, provider health, reconciliation reports.

Field-level details, schema-specific identifiers, exact threshold values, and proprietary algorithms are intentionally omitted from this document. Specifics are available to vetted partners under standard non-disclosure terms.

How we ship · how we scale

Quality gate

A comprehensive automated test suite runs against a real browser on every change — covering player journeys, operator journeys, and a regulator-aligned control matrix that maps directly to the LCCP, ISO 27001, OWASP, PDPA, FATF, and Tanzania Gaming Board expectations. Adversarial scenarios — credential stuffing, privilege-escalation attempts, race conditions on settlements, payload abuse, age tampering — are part of the standing test floor, not an afterthought.

Deployment posture

Cloud-platform-agnostic. The application requires only a Node 22+ runtime and a managed PostgreSQL endpoint via a standard connection string. Database schema migrations are applied automatically on deploy. Daily backups with weekly external archive into cold storage cover the regulator-mandated five-year retention window.

Observability

Standard liveness and readiness probes, structured per-request logs keyed to a request identifier, and a hash-chained audit log that can be joined back against the application logs for full forensic context. Any platform's built-in monitoring layer can be wired in without code change.

Scaling path

- **Read replicas** for analytics and the operator console as transaction volume grows.
- **Connection pooling** via a standard pooler — one configuration swap, no application code change.
- **Multi-instance deployment** behind a load balancer — sessions are signed not stored, so any instance verifies any session without a shared cache.
- **Asynchronous audit writer** — the chain becomes the slow tier; the request path stays sub-fifty milliseconds at peak.

What this brief intentionally does not contain

Implementation specifics that would benefit an attacker or a competitor — exact rate-limit parameters, hashing-function parameters, audit-secret location, proprietary pool mathematics, AML threshold values, internal endpoint surfaces. Specifics are available to vetted partners under standard non-disclosure terms.

External dependencies before public launch

Every item below is the platform waiting on an external party — a regulator, a telecommunications authority, a payment partner, or a final hosting decision. None are engineering blockers; the platform is feature-complete, the controls are in place, and the integrations are abstracted behind switchable provider adapters.

PENDING • REGULATOR

Tanzania Gaming Board licence. Pre-application meeting and written classification of the pari-mutuel pool model as betting. Pre-application packet drafted; legal counsel engaged.

PENDING • TELCO

SMS-OTP delivery. Awaiting a TCRA-licensed sender ID and a contracted Tanzanian SMS gateway. Provider abstraction is in place — switch is configuration only.

PENDING • AGGREGATOR

Mobile-money payment integration. Awaiting the signed aggregator agreement covering deposit and withdrawal across every major Tanzanian mobile-money provider. Deposit and withdraw adapters are scaffolded behind the same provider abstraction.

PENDING • HOSTING

Email transactional sending. Reputable transactional email provider (account confirmations, RG digests, regulator exports) configured once the final production hosting environment is selected.

PENDING • HOSTING

Domain, certificates, monitoring. Final domain pointing, TLS certificates, observability stack wiring, log retention sizing, alerting rules. Standard infrastructure work that lands once the host is chosen.

PENDING • PARTNER

Live match-integrity feed. Sportradar Integrity Services (or equivalent) for football market resolution at scale. Anti-fraud module ingest hook is already in place.

Specifics on every item above — partner shortlists, integration timelines, and provider-side technical readiness — are available to vetted partners under standard non-disclosure terms.